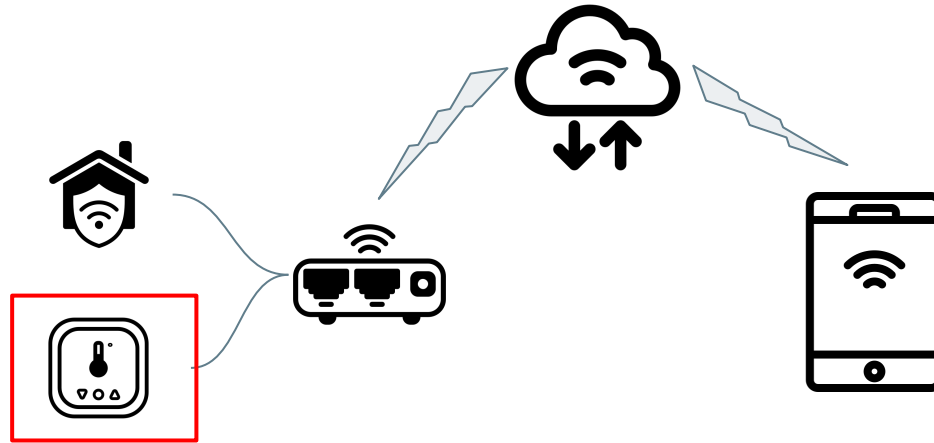


Threat Modeling IoT System

IoT System





Threat Model

What to protect? IoT Device

Attacker Capabilities?

What can attacker do?

How to prevent?





Threat Model

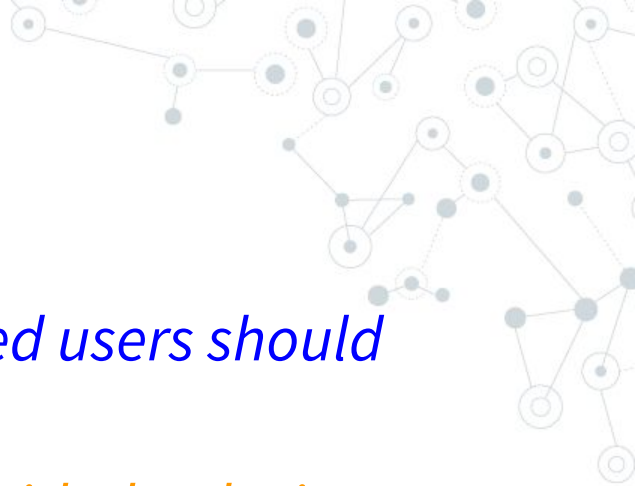
What to protect? *IoT Device; only authorized users should be able to operate;*

Attacker Capabilities?

What can attacker do?

How to prevent?





Threat Model

What to protect? *IoT Device; only authorized users should be able to operate;*

Attacker Capabilities? *Can communicate with the device.*

What can attacker do?

How to prevent?



Threat Model

What to protect? *IoT Device; only authorized users should be able to operate;*

Attacker Capabilities? *Can communicate with the device.*

What can attacker do (Attacker 1)? *Impersonate an authorized user. Try to Get added to authorized users.*

How to prevent?

Threat Model

What to protect? *IoT Device; only authorized users should be able to operate;*

Attacker Capabilities? *Can communicate with the device.*

What can attacker do (Attacker 1)? *Impersonate an authorized user. Try to Get added to authorized users.*

How to prevent? *Add Authorization mechanism; Only authorized users can add new users.*

IoT Device: Attacker capabilities

- Can communicate with device.

IoT Device: Attacker capabilities

- Can communicate with device.
- Can listen to the traffic.
- Can modify the traffic.

IoT Device: Attacker capabilities

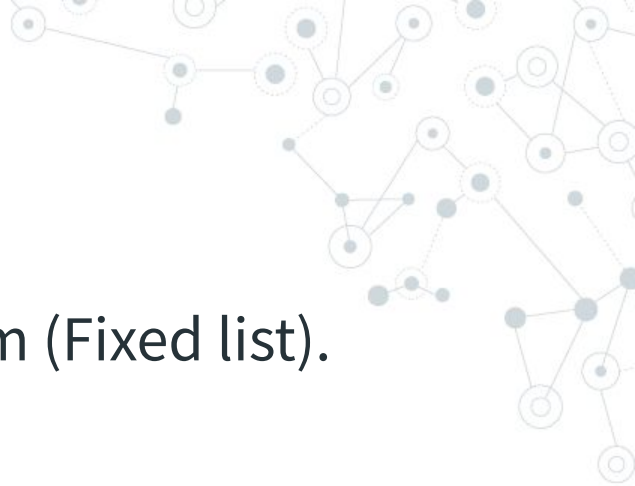
- Can communicate with device.
 - **Impersonation.**
- Can listen to the traffic.
 - **Reconnaissance.**
- Can modify the traffic.
 - **Alter commands.**

IoT Device: Attacker capabilities

- Can communicate with device.
 - **Impersonation** => **Authorization mechanism.**
- Can listen to the traffic.
 - **Reconnaissance** => **Network Confidentiality.**
- Can modify the traffic.
 - **Alter commands** => **Integrity.**

IoT Device: Threat Modeling (Challenges)

- Should be able to identify realistic attacker capabilities.
 - What are realistic capabilities? Also, **should we list all possible capabilities? Some capabilities might be irrelevant for a device** (e.g., ability to see device for a thermostat)
- Should be able to identify possible threats based on these capabilities.



Practical (Reverse) Threat Modeling

- Find all possible threats to your system (Fixed list).
 - Identify how an attacker might do em (Relevant Attack Vectors and Capabilities).
 - Prevent attacker from doing em (Security Mechanisms).
- 

Practical (Reverse) Threat Modeling

- Find all possible threats to your system (Fixed list).
 - Microsoft STRIDE
- Identify how an attacker might do em (Relevant Attack Vectors and Capabilities).
 - Map the threats using MITRE ATT&CK Framework

Prevent attacker from doing em (Security Mechanisms).
MITRE Mitigations

Microsoft STRIDE Framework

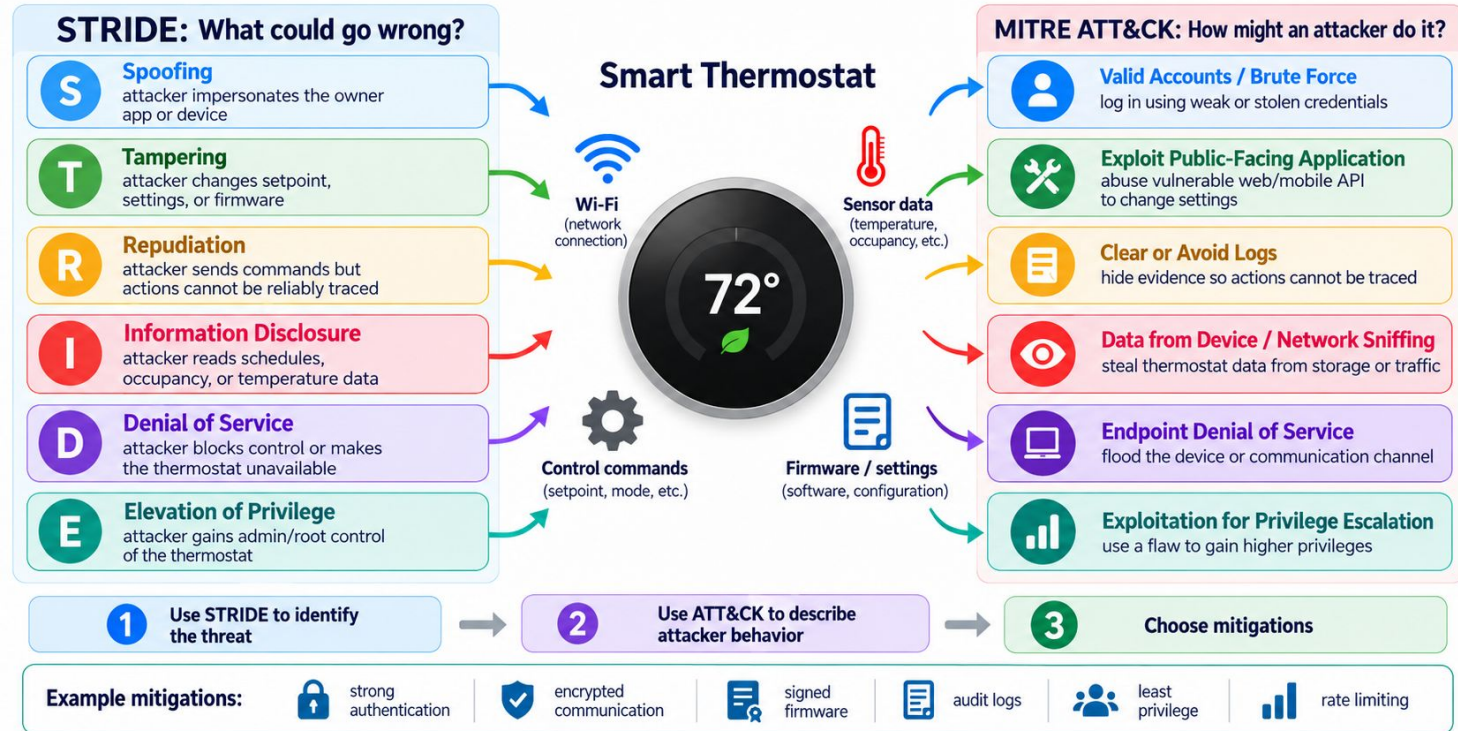
- (S)poofing: Impersonation.
- (T)ampering: Unauthorized Modifying.
- (R)epudiation: Denying actions (stealth).
- (I)nformation Disclosure: Unauthorized accesses.
- (D)enial of Service: Deny service for legitimate access.
- (E)levation of Privileges: Gaining additional privileges.

MITRE ATT&CK Framework

Adversarial Tactics, Techniques and Common Knowledge

ATT&CK Matrix for Enterprise						
layout: side ▾ show sub-techniques hide sub-techniques						
Initial Access	Execution	Persistence	Privilege Escalation	Stealth	Defense Impairment	Credential Access
techniques	20 techniques	22 techniques	13 techniques	30 techniques	18 techniques	17 techniques
Phishing	BITS Jobs	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Access Token Manipulation (5)	Disable or Modify System Firewall (3)	Adversary Persistence
Drive-by Compromise	Cloud Administration Command	BITS Jobs		BITS Jobs	Disable or Modify Tools (6)	Brute Force
Malicious File Execution	Command and Scripting Interpreter (13)	Boot or Logon Autostart Execution (14)	Access Token Manipulation (5)	Build Image on Host	Domain or Tenant Policy Modification (2)	Credential Theft from Password Store
Malicious Software	Container Administration Command	Boot or Logon Initialization Scripts (5)	Account Manipulation (7)	Debugger Evasion		Explicit for C&A
Malware	Deploy Container	Cloud Application Integration	Boot or Logon Autostart Execution (14)	Deobfuscate/Decode Files or Information	Downgrade Attack	Force Authentication
	ESXi		Boot or Logon Initialization	Direct Volume Access	Exploitation for Defense Impairment	
				Execution		

Thermostat Threat Modeling



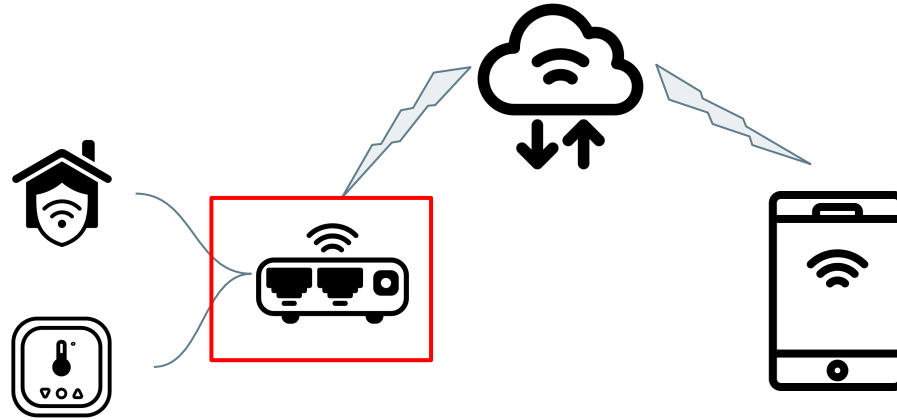
Doorlock Threat Modeling



Smart Door Lock

STRIDE Threat (for door lock)	Example threat	Relevant MITRE ATT&CK technique (example)	How an attacker might cause it (example scenario)
 Spoofing (pretending to be someone or something)	Attacker impersonates an authorized user or the mobile app.	T1078 – Valid Accounts T1550 – Use Alternate Authentication Material	Attacker steals the user's credentials (phishing) and logs in to the mobile app, then sends an unlock command.
 Tampering (modifying data or code)	Attacker modifies commands, firmware, or configuration.	T1565 – Data Manipulation T1601 – Modify System Firmware	Attacker intercepts traffic and changes an "lock" command to "unlock", or installs modified firmware that disables locking.
 Repudiation (denying an action)	User denies they unlocked the door (insufficient logging or audit).	T1070 – Indicator Removal on Host T1562 – Impair Defenses	Attacker clears or alters lock logs on the device or in the cloud so the unlock event is not recorded.
 Information Disclosure (leaking sensitive information)	Attacker learns unlock codes, user identities, or access patterns.	T1041 – Exfiltration Over C2 Channel T1110 – Brute Force (also used to discover valid codes)	Attacker eavesdrops on unencrypted communication to capture access tokens, or gathers user data from the cloud and exfiltrates it.
 Denial of Service (making it unavailable)	Attacker prevents the lock from functioning (e.g., battery drain, network jam, crash).	T1499 – Endpoint Denial of Service T1498 – Network Denial of Service	Attacker floods the lock with connection requests or jams the wireless signal, preventing it from receiving valid unlock commands.
 Elevation of Privilege (gaining higher access)	Attacker gains admin access to the lock or cloud service.	T1068 – Exploitation for Privilege Escalation T1548 – Abuse Elevation Control Mechanism	Attacker exploits a firmware vulnerability to gain root access, then adds a new admin user with permanent unlock rights.

IoT System



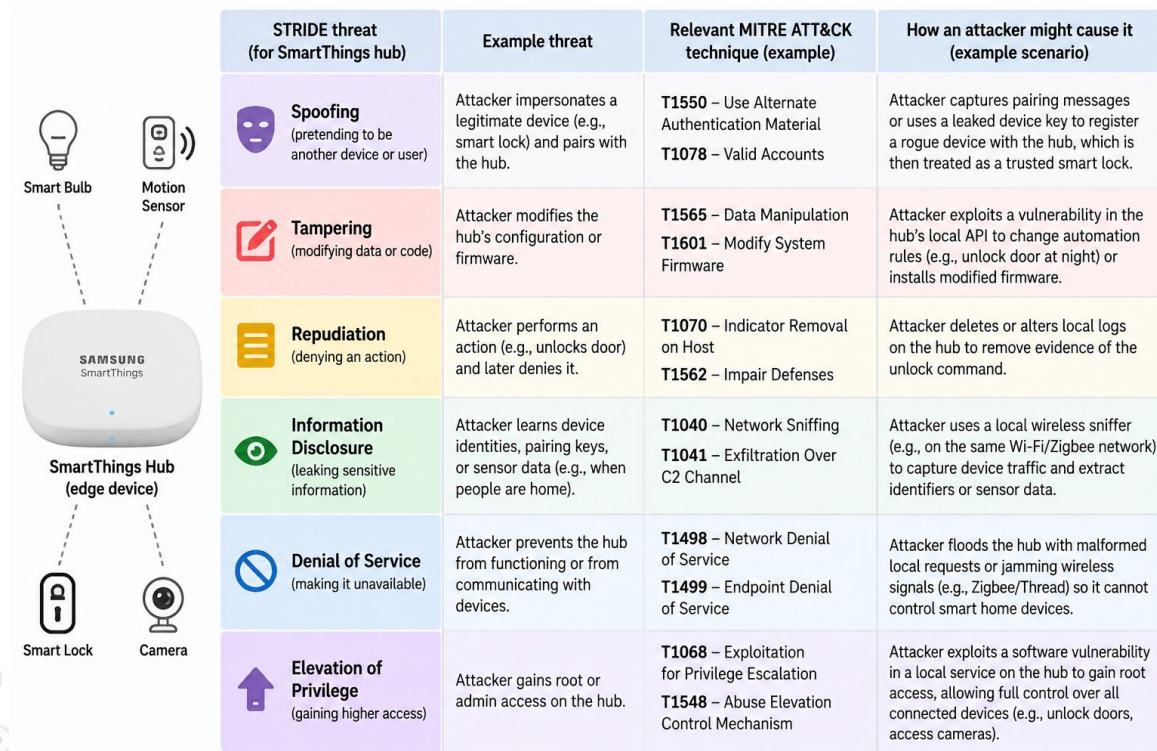
Edge/Hub Device

- Interacts with users (via controller/cloud).
- Interacts with multiple (often related) devices.

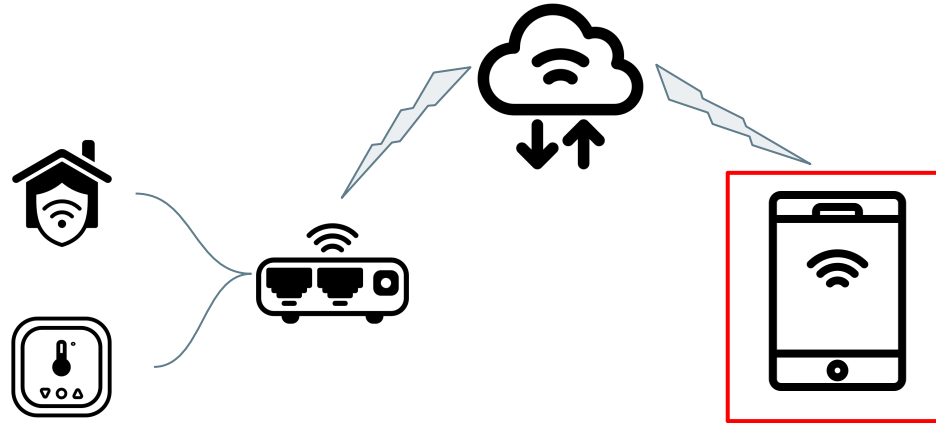
Edge/Hub Threat Modeling: STRIDE

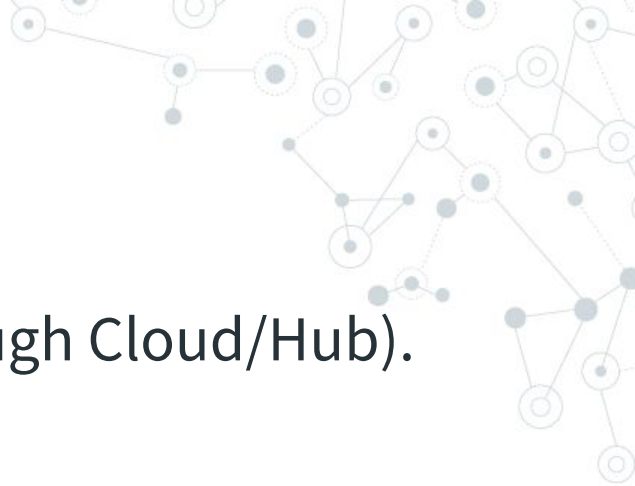
- (S)poofing: Spoofing an IoT device.
- (T)ampering: Modifying configuration or communication.
- (R)epudiation: Denying actions (stealth).
- (I)nformation Disclosure: Unauthorized accesses.
- (D)enial of Service: Deny service for legitimate access.
- (E)levation of Privileges: Gaining additional privileges.

Edge/Hub Device: Threat Model



IoT System

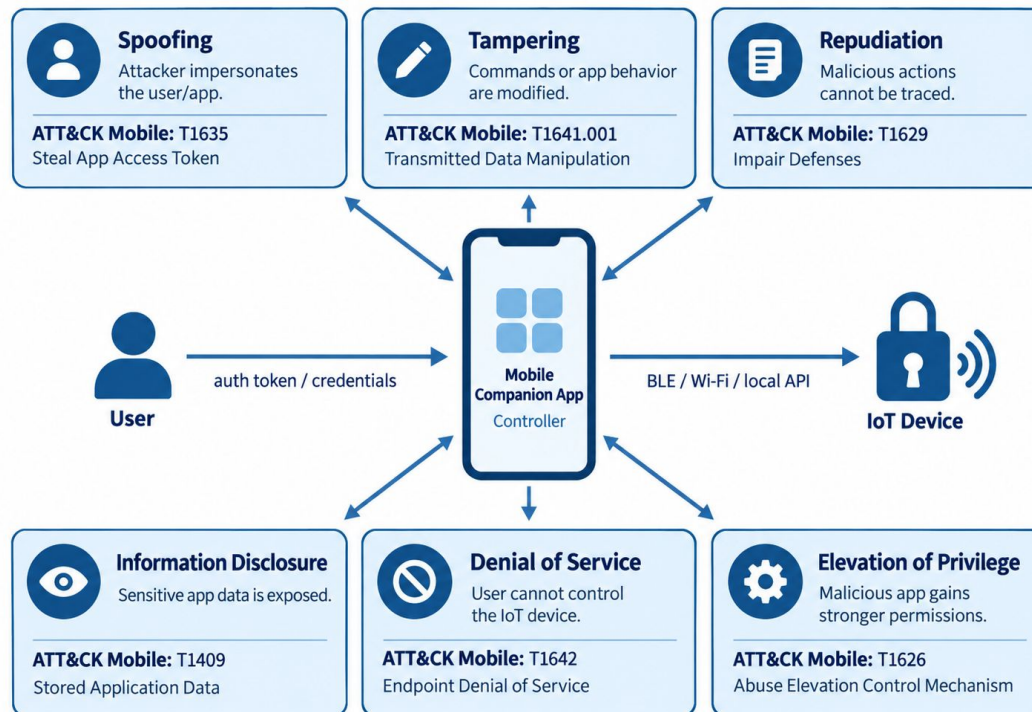




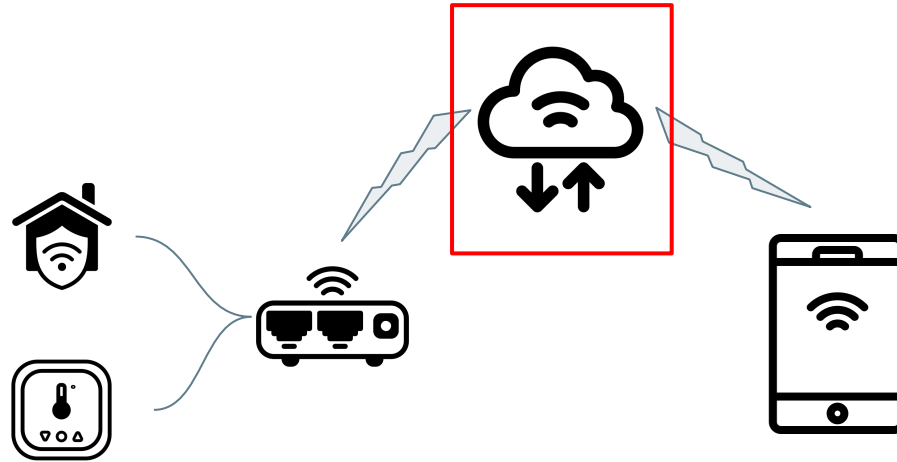
Controller (Companion App)

- Interacts with device (directly or through Cloud/Hub).
- Interacts with user.

Companion App: Threat Model



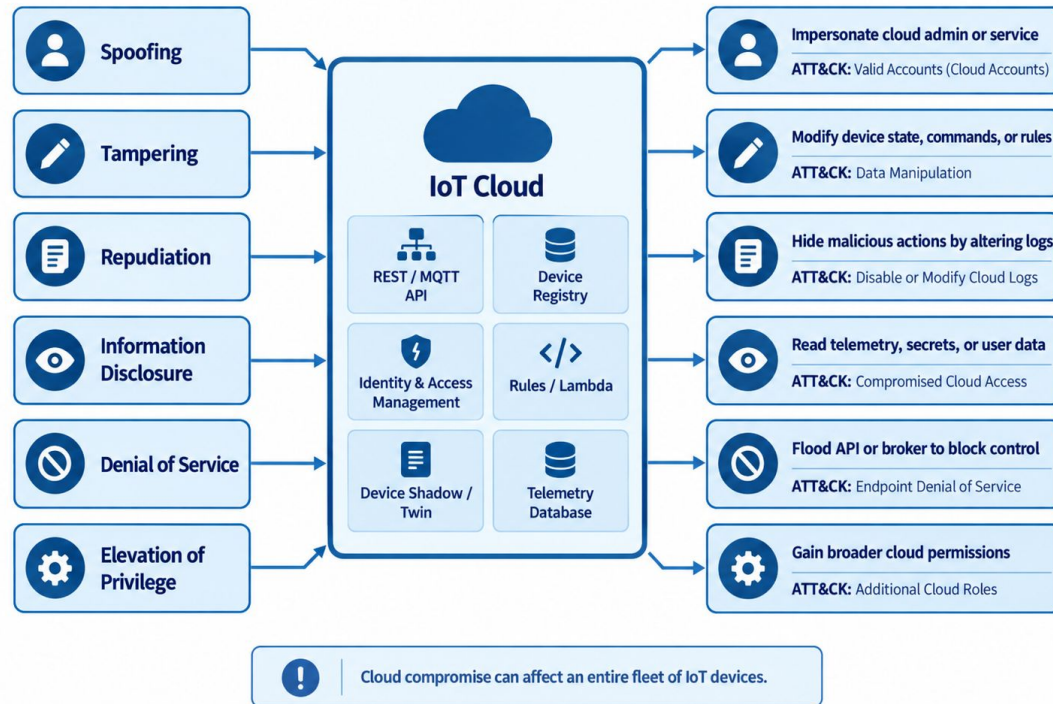
IoT System



Cloud App/Component

- Interacts with multiple users.
- Interacts with multiple (unrelated) devices.

Cloud Component: Threat Model



STRIDE Principles

- (S)poofing: Self or third party.
- (T)ampering: Unauthorized or unintended modifications.
- (R)epudiation: Denying actions (stealth).
- (I)nformation Disclosure: Unauthorized accesses.
- (D)enial of Service: Deny service for legitimate access.
- (E)levation of Privileges: Gaining additional privileges.